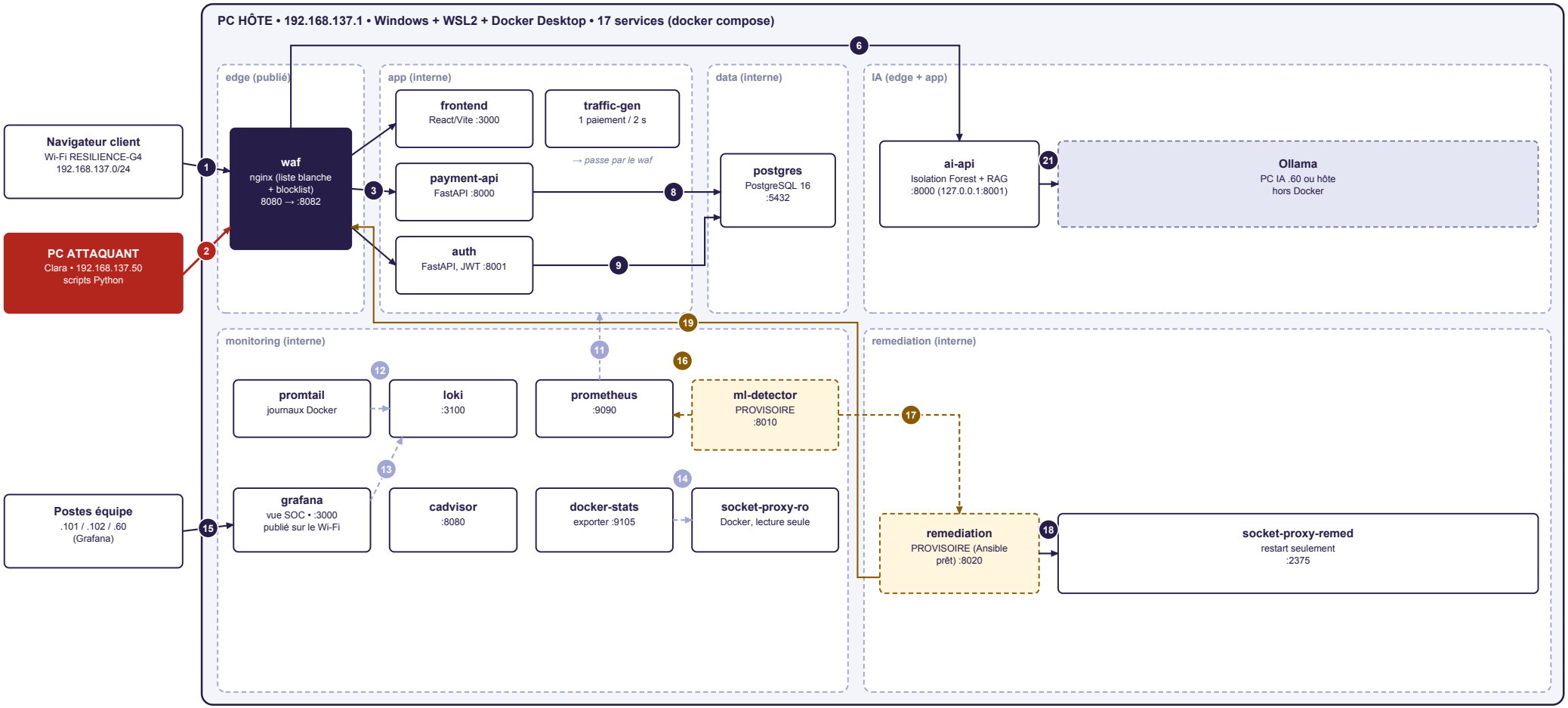
PARTIE 1

Schéma d'architecture technique (tel que construit)

17 services Docker sur le PC Hôte • 5 réseaux • seuls le WAF (8082) et Grafana (3000) sont publiés • lu dans le code le 21/10



Légende : **rouge** = attaque • **trait plein** = flux applicatif • **pointillés violets** = supervision • **orange** = remédiation (cadres pointillés orange = conteneurs provisoires)

1 Navigateurs du Wi-Fi → waf (:8082)
2 PC Attaquant .50 → waf : **attaque**
3 waf → frontend, payment-api, auth
6 waf → ai-api (/ai/)
8 payment-api → postgres
9 auth → postgres
11 prometheus → services : métriques
12 promtail → loki : journaux
13 grafana → prometheus, loki
14 docker-stats, cadvisor, promtail → socket-proxy-ro
15 postes équipe → grafana (:3000)
16 ml-detector → prometheus, loki *(prévu)*
17 ml-detector → remediation *(prévu)*
18 remediation → socket-proxy-remed : redémarrage
19 remediation → waf : blocage + paiement de test
21 ai-api → Ollama (PC IA)

PARTIE 2

Analyse de risques EBIOS RM — Atelier 1

Ce qu'on protège, ce qu'on redoute, et ce qui nous protège déjà

Contexte : une entreprise financière fictive fait tourner une plateforme de paiement en ligne. L'étude porte sur **notre démonstrateur**, décrit par le schéma de la partie 1. Pas de vraies données bancaires, pas de numéros de carte.

1 Ce qu'on doit protéger

	Valeur métier	Pourquoi c'est important
VM1	**Traitement des paiements**	Un client doit pouvoir payer à tout moment, en quelques secondes
VM2	**Intégrité comptable des comptes**	Soldes exacts, aucun paiement débité deux fois
VM3	**Confidentialité des secrets**	Mots de passe et clés (PostgreSQL, JWT, Grafana) jamais exposés
VM4	**Traçabilité et observabilité**	Des journaux disponibles pour enquêter, sans fuite d'informations
VM5	**Authentification des clients**	Seul le titulaire d'un compte peut payer en son nom
VM6	**Données des clients**	Elles ne doivent jamais sortir de la plateforme

Numérotation commune avec le rapport cyber de Clara (VM1 à VM4), complétée par VM5 et VM6.

2 Comment on note la gravité

Niveau	Ça veut dire
G2 — Significatif	Gêne pour quelques clients, aucune perte d'argent, le service revient vite
G3 — Grave	Paiements bloqués longtemps ou groupe de clients touché. Incident à déclarer aux autorités (DORA)
G4 — Critique	Perte d'argent, contrôle total de la plateforme par un pirate, ou fuite massive de données

Le niveau G1 (aucun impact visible) n'apparaît pas dans notre liste.

3 Ce qu'on redoute

	Ce qu'on redoute	Touche	Gravité	Ce qui nous protège déjà
ER1	**Les paiements ne passent plus** : un flood sature l'API ou la base (SC-01)	VM1	**G3**	WAF qui limite le débit, détection ML, IP de l'attaquant bannie automatiquement
ER2	**Un paiement est faux** : double débit, montant modifié	VM2	**G4**	Paiement enregistré en une seule requête (tout ou rien)
ER3	**Un pirate entre dans le compte d'un client** : il teste des milliers de mots de passe	VM5	**G3**	Nombre d'essais limité sur /login, détection ML
ER4	**Un pirate vole nos secrets** (clé JWT, mots de passe) et peut tout faire	VM3	**G4**	Secrets chiffrés avec SOPS, clé JWT présente uniquement dans auth
ER5	**Les données clients fuient** : injection SQL	VM6	**G3**	Règles anti-injection du WAF, base inaccessible depuis le réseau
ER6	**Notre moteur de réparation est détourné ou se trompe** (il bannit des vrais clients)	VM1, VM4	**G4**	Accès à Docker limité, aucune commande possible de l'extérieur, transaction test avant de dire « rétabli »
ER7	**Le PC Hôte tombe** : tout tourne dessus	Toutes	**G3**	Playbook Ansible pour tout réinstaller vite (mais pas de second PC)

4 Ce qu'il faut retenir

- **Les risques les plus graves (G4) ne sont pas ceux de la démo** : paiement faux, vol des secrets, moteur de réparation détourné. On les évite **dès la conception** de l'architecture.
- **La démo montre ER1 et ER3** (flood, force brute) : le système détecte l'attaque et se répare seul.
- **Notre point faible** : tout repose sur un seul PC (ER7). C'est un risque qu'on accepte pour un prototype de 4 jours, et qu'on citera dans le PCA/PRA.

5 Les règles qui s'appliquent

Règle	Pour nous
DORA	La règle principale : on est une entreprise financière (elle passe avant NIS2)
NIS2	Sert de référence pour les bonnes pratiques de sécurité
RGPD	Données fictives, mais on les protège comme si elles étaient réelles

Ce qu'on ne fait pas (et qu'on dira au jury) : pas de HTTPS, pas de second PC, pas de sauvegarde hors du PC, pas de déclaration réelle aux autorités.

6 Prochaines étapes

- □ **Aujourd'hui** : 15 min avec l'équipe pour valider les gravités, puis présentation au coach.
- □ **Ensuite** : qui pourrait nous attaquer et pourquoi (atelier 2), puis le déroulé de l'attaque de Clara (atelier 4).
- □ **Mercredi** : ces risques deviennent le PCA/PRA (temps de reprise visé, ce qui reste à risque).